

The Red and the Blue: a tale of stealth and detection

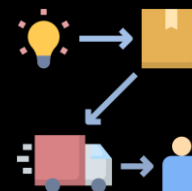
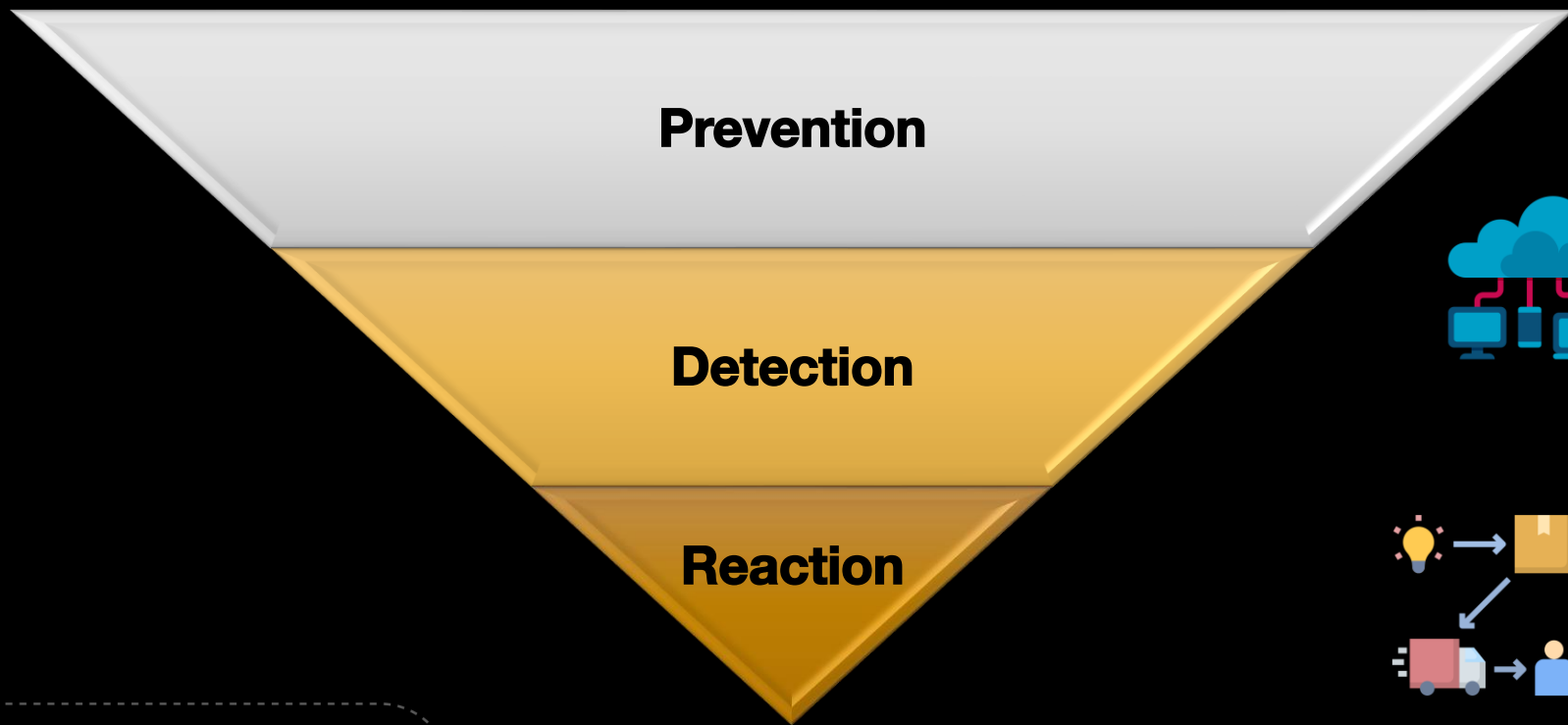


leHACK 2024

Presentation of myself

- **Head of Red Team @ Orange Cyberdefense France**
- **12 years in Offensive Security**
- **Source Code Review, Penetration Tests (Web, mobile, network), Active Directory, Trainings**
- **Last 5 years focusing on Red Teaming and Purple Teaming**
- **Certifications, publications and CVEs**

Introduction



Why this talk ?

- Lack of resources on stealth and detection
- Common questions for Red and Blue Teamers:

How could I
achieve my goal
without being
detected ?

How to improve
our defense
capabilities ?

Is this action
flag?

How can I
progress without
blowing the whole
operation ?

Are we missing
critical intrusion
?

How to react to
this alert ?

Learning outcomes

- Understand stealth and detection
- Overview of Red Team and Blue Team ecosystems
- Introduction to stealth and detection considerations as well as response strategies
- Real-world examples and lessons learned

Understanding Red and Blue Teams



Red Team

- Simulate real-world attacks to test an organization's defenses
- Improve overall security posture through adversarial tactics
- Organization:
 - 2 to 5 members
- Roles:
 - Red Team Operators / Leader (former Penetration testers)
 - Exploit developers
 - Threat emulation specialists
- Tools and skills:
C2, Maldev, Evasion, Social Engineering, Phishing, AD, ...

Blue Team



- Monitor, detect, and respond to security incidents
- Protect organizational assets from cyber threats
- Organization:
 - Security Operations Center (SOC)
 - Computer Emergency Response Team (CERT)
- Roles:
Analysts, incident responders, forensic expert, threat hunter, security engineers, TI analyst, offensive security expert, ...
- Tools and skills:
Sysmon, Yara, EDR, NDR, Proxy, SIEM, Firewall, RE

Stealth and detection considerations

- Definitions of stealth:

stealth

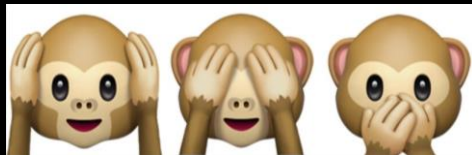
noun [U]

UK  /stelθ/ US  /stelθ/

movement that is quiet and careful in order not to be seen or heard

Stealth, Military. a U.S. Air Force project involving a range of technologies, with the purpose of developing aircraft that are difficult to detect by sight, sound, radar, and infrared energy.

- No action is truly invisible in cybersecurity. The stealth notion is thus relative to the eyes and ears of the Blue Team and its ecosystem:



Red Teams Stealth considerations

- Stealth is paramount in Red Team operations
- Meticulously manage activities
- Each action should be seen as a footprint left in the company
 - Leave footprints that could not be correlated, preventing the BT to get the bigger picture
 - Prioritize footprints not corresponding to well-known detection rules
 - Avoid footprints known as bad
- Various forms



Red Teams Stealth considerations

- What to avoid ?

Examples of behavioral blocking and containment in action

Behavioral blocking and containment capabilities have blocked attacker techniques such as the following:

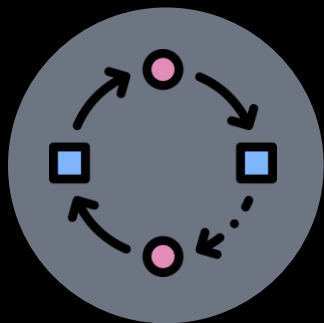
- Credential dumping from LSASS
- Cross-process injection
- Process hollowing
- User Account Control bypass
- Tampering with antivirus (such as disabling it or adding the malware as exclusion)
- Contacting Command and Control (C&C) to download payloads
- Coin mining
- Boot record modification
- Pass-the-hash attacks
- Installation of root certificate
- Exploitation attempt for various vulnerabilities

Red Teams Stealth strategies

- Main goal: leave undetectable or uncorrelated “footprints”



Red Teams Stealth strategies



Adapt



Custom



Lab



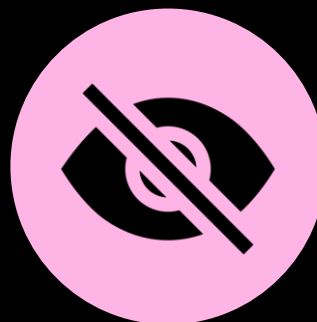
Blend in



Low & slow



Balance



Blind spots

Blue Team Detection consideration

- Detecting stealthy action is challenging, but not impossible

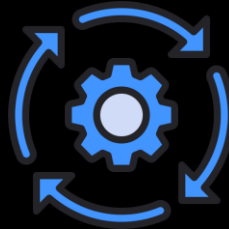
EDR & NDR

Sysmon

SIEM

Blue Teams Detection and Response strategies

- Investigate
- Continuous Monitoring and Automated Alerts
- Threat Hunting
- Incident Response Procedures
- Regular Exercises



Common Blue Team Errors

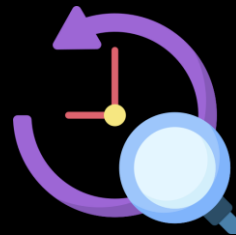
- Rely on signature based detection
- Insufficient visibility
- Poor communication
- Wrong interpretation / evaluation
- Log retention
- ...



Common Blue Team Errors

➤ Real World examples from Red Team engagements:

1. Mimikatz on server
2. Domain admin account created from another domain account
3. Some phishing that goes unnoticed



Blind Spots in Detection

- Area within an organization's cybersecurity defenses where security monitoring and threat detection capabilities are insufficient or nonexistent.
- Gap or void in the visibility of security events or activities that may leave the organization vulnerable to undetected threats or attacks.
 - network traffic, endpoint activities, user behavior, and application vulnerabilities.
- Reasons for blind spots :

**Lack of
monitoring
coverage**

**Ineffective
detection tools**

**Insufficient log
collection and
analysis**

**Data complexity
and volume**

**Evasion
techniques**



Blind Spots example

- Cookie dumping technique detection rule



- Blind Spot



- To mitigate this blind spot, Blue Teams may need to implement additional detection mechanisms



Case study: handling of an infection

- Let's assume that a targeted attack happened and that at some point, a critical alert is raised on the Blue Team side.
- We will see how this incident could be handled by several Blue Teams with different maturity levels, based on my experience.
- As we move onto more mature Blue Teams, we will discover bigger and bigger damages in the company's internal network, showing the importance of proper incident handling.

Level 0 – No detection

- Attack goes completely undetected
- Potential for significant data loss and prolonged breach
- 0 beacon found

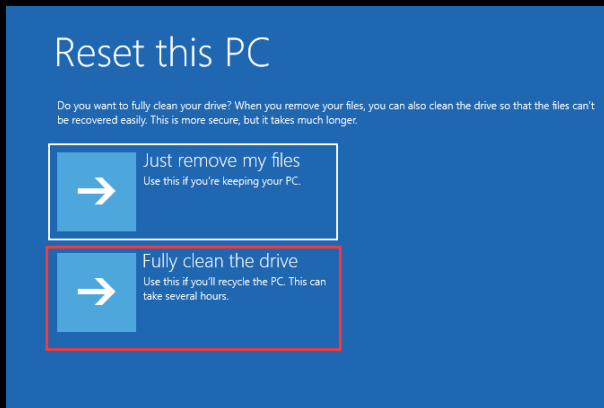


In the meantime...



Level 1 – Isolate and format

- **Compromised computers are immediately isolated and formatted without further investigation**
- **Loss of potential forensic evidence, inability to understand the root cause of the attack**
- **1 beacon found**



Level 2 – Identify file and sign

- Malicious files are identified, and signature are checked across the network
- Limited detection capability against polymorphic malware or advanced threats using different file signatures
- 2 beacons found



Level 3 – Partial Incident Response Analysis

- Victims are interviewed to gather information
- Some IOCs (emails, domains, hash, IP, etc.) are extracted and blocked
- Historical research performed
- 3 beacons found



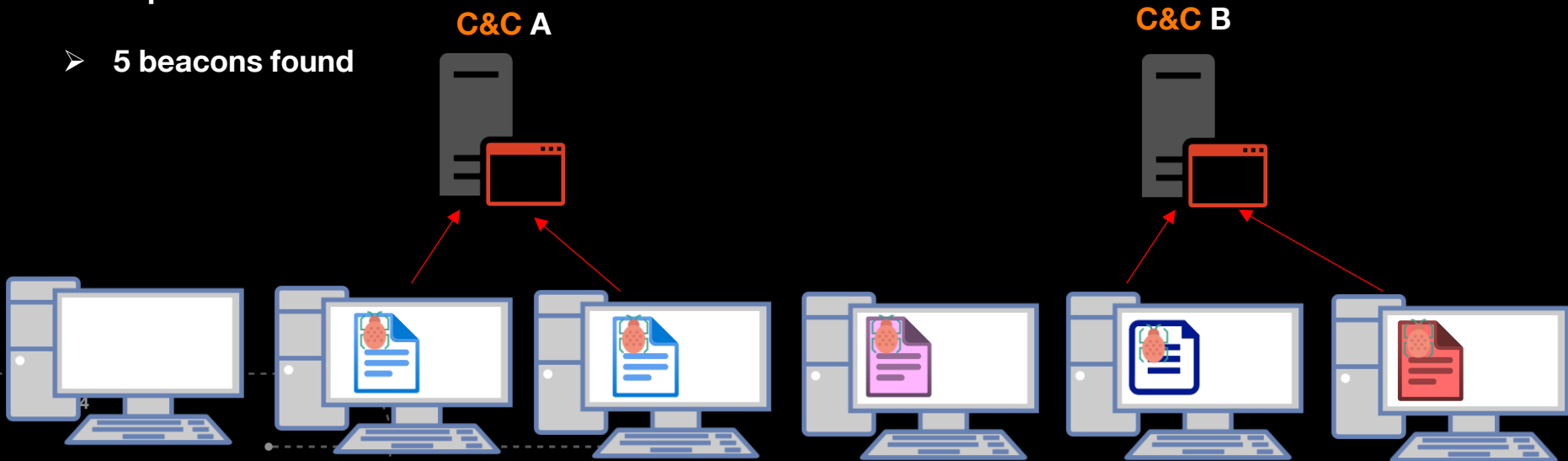
Level 4 - Develop Generic Detection Rules

- Understand technique used by attacker
- Create generic detection rules to catch similar threats
- Potential for increased false positives
- 4 beacons found



Level 5 - Dynamic Behavioral Analysis

- Detect C2 and beaconing behavior to correlate with previous techniques
- Focuses on detecting unusual behavior patterns rather than just known signatures
- Improved detection of threats using different C2 domains, but requires sophisticated tools and expertise
- 5 beacons found



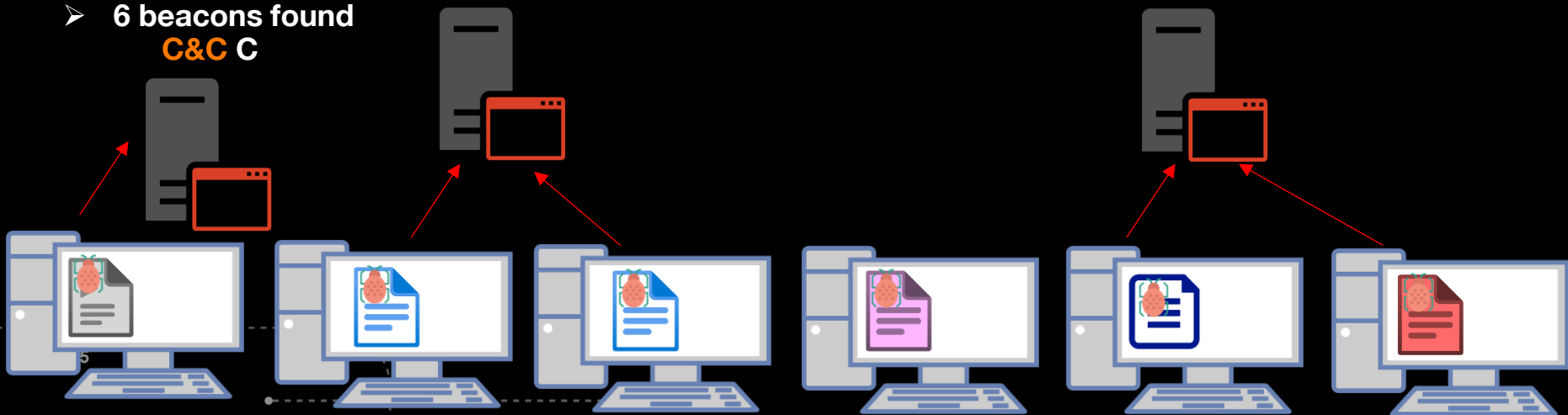
Level 6 - Proactive Threat Hunting

- Threat hunting activities to search for signs of compromise or APTs that may evade automated detection mechanisms
- Active and ongoing search for potential threats, even without specific alerts or indicators
- Improved detection of threats but requires sophisticated tools and expertise
- 6 beacons found

C&C C

C&C A

C&C B



Handling of an incident details

- Suspicious Email
- Analysis and potential IOCs extraction:
- Perform historical research
 - Isolate and analyze workstations
 - Interrogate users to understand
 - Pull out more IOCs
- Block on security equipment
- Create detection rules



Handling of an incident details

- **Analyze websites and extract potential IOCs:**
- **Perform historical research**
 - **Isolate and analyze workstations**
 - **Interrogate users to understand**
 - **Pull out more IOCs**
- **Block on security equipment**
- **Create detection rules**



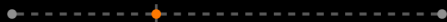
Handling of an incident details

- **Analyze artifacts and potential IOCs extraction:**
- **Perform historical research**
 - **Isolate and analyze workstations**
 - **Interrogate users to understand**
 - **Pull out more IOCs**
- **Block on security equipment**
- **Create detection rules**

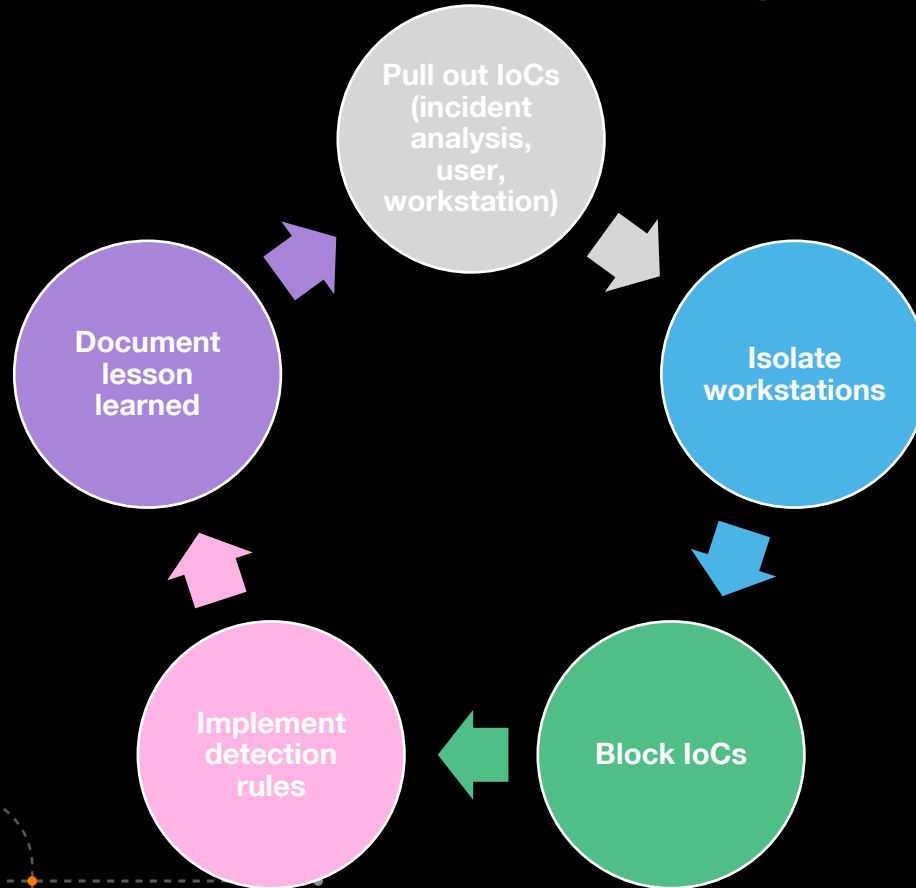


Handling of an incident details

- **Document**
 - **lessons learned**
 - **best practices for improving detection and response processes**
- **Refine detection criteria**
- **Update monitoring configurations**
- **Enhance incident response procedures**

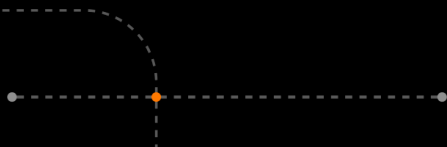


Handling of an incident summary

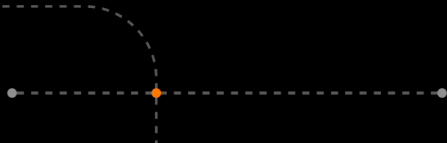


Wrap-up

- **Stealth: The art of avoiding detection by security mechanisms**
- **Being Stealthy: Using techniques that minimize footprints and evade detections in place**
- **Defending Against Stealthy Attackers:**
 - **Implementing robust detection and response strategies**
 - **Proactive Threat Hunting**
 - **Keep doing Red Teams & Purple Teams**



Questions ?





Cyberdefense